

[Bugs] Protential ReDoS bug in caption.py #2716

Closed

#2717

ShangzhiXu opened on Jul 21, 2025 · edited by ShangzhiXu

Edits ...

Description

Describe the bug

Describe the bug

Hi team, thanks for your great work! I think I found a bug that might lead to DDoS in the system

At line 34 in caption.py

the regex `RE_FIG_NUM = re.compile(r'^(\^)?([1-9][0-9]*(?:.[1-9][0-9]*)*)(?=[\s]|$)')` is vulnerable to ReDoS when it is used in

```
m = RE_FIG_NUM.match(argument)
```

PoC

I have a test file to stimulate the user input handled by this regex

```
import re
import time

regex_pattern = re.compile(r'^(\^)?([1-9][0-9]*(?:.[1-9][0-9]*)*)(?=[\s]|$)')

for i in range(50, 500, 50):
    long_string = '1' * i + 'a'
    start_time = time.time()
    match = re.match(regex_pattern, long_string)
    end_time = time.time()
    print(f"long_string execution time: {end_time - start_time:.6f} s")
```

The result system will hang for more than 1 hour here

If using pymdown in a server setup, this bug may lead to high CPU usage or DoS risks if users submit malicious or resource-intensive repositories.

Expected behavior

I think we can add a limit like replace `.*?` with `.{0,200}?` ? Maybe it can help to solve the recursion problem.

The core of the problem lies within `(.)*?`. It leads to massive recursion and backtracking when faced with malicious input.

Minimal Reproduction

like above~

Version(s) & System Info

- Operating System: ...
- Python Version: ...
- Package Version: ...

🗨 1

 **ShangzhiXu** added **T: bug** on Jul 21, 2025

 **gir-bot** added **S: triage** on Jul 21, 2025

 facelessuser on Jul 22, 2025

Owner ...

We accidentally used `.` instead of `\.`.

Here is the fixed pattern:

```
import re
import time

regex_pattern = re.compile(r'^(\^)?([1-9][0-9]*(?:\.[1-9][0-9]*)*)(?=[|$]')

for i in range(50, 500, 50):
    long_string = '1' * i + 'a'
    start_time = time.time()
    match = re.match(regex_pattern, long_string)
    end_time = time.time()
    print(f"long_string execution time: {end_time - start_time:.6f} s")
```

And results

```
→ pymdown-extensions git:(main) x python3 example.py
long_string execution time: 0.000008 s
long_string execution time: 0.000007 s
long_string execution time: 0.000008 s
long_string execution time: 0.000009 s
long_string execution time: 0.000011 s
long_string execution time: 0.000013 s
long_string execution time: 0.000015 s
long_string execution time: 0.000016 s
long_string execution time: 0.000019 s
```

🗨 2

 **facelessuser** mentioned this on Jul 22, 2025

 [Caption pattern should match a literal dot #2717](#)



 **facelessuser** closed this as completed in [#2717](#) on Jul 22, 2025



 **jonasbn** mentioned this 2 weeks ago

 [Security patch for dependency pymdown-extensions rojopolis/spellcheck-github-actions#313](#)

[Sign up for free](#) to join this conversation on **GitHub**. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

S: triage

T: bug

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development



Code with agent mode



Caption pattern should match a literal dot

facelessuser/pymdown-extensions

Participants

